

Ответы на вопросы

1. Почему необходимо защищаться?

— Защищаться в информационных системах необходимо из-за человеческого фактора (шпионаж, экономический интерес, несанкционированный доступ) и наличия в них уязвимостей, которые используются для компьютерного шпионажа. Даже стандартные средства защиты (например, криптография) могут быть "прозрачными" для специальных служб некоторых стран, что делает безопасность информации еще более критичной.

2. Источники и последствия реализации угроз ИБ

— Основным источником угроз информационной безопасности является противоправная деятельность человека (или группы людей), чьи действия непредсказуемы.

Все последствия реализации угроз можно сгруппировать в четыре основных вида:

1) Вскрытие: Несанкционированный доступ к конфиденциальной информации (например, через перехват, кражу данных или взлом).

2) Обман: Введение в заблуждение полномочных пользователей с помощью искаженных данных (например, маскарад или фальсификация).

3) Разрушение: Нарушение или прекращение корректной работы системы (например, путем ее повреждения, вывода из строя или создания помех).

4) Захват (Узурпация): Незаконный захват контроля над системой или ее ресурсами.

Конечными целями всех этих угроз являются конфиденциальность и целостность информации пользователей, а также работоспособность самой информационной системы.

3. Функция, способы и средства обеспечения ИБ

— Для обеспечения информационной безопасности в информационно-телекоммуникационных системах (ИТС) вводится дополнительная функция безопасности, которая распределяется по уровням сетевой архитектуры (например, ЭМВОС или Интернет). Эта функция реализуется через:

- Способы обеспечения ИБ (СПБ): Совокупность приёмов и операций для достижения целей защиты.
- Средства обеспечения ИБ (СРБ): Конкретные технические устройства (аппаратные, программные), реализующие эти способы.

Архитектура безопасности строится на принципе распределения подфункций защиты по уровням сети, где каждый уровень защищает от наиболее характерных для него угроз, избегая избыточного дублирования.

4. Архитектура безопасности ЭМВОС

— Архитектура безопасности ЭМВОС (стандарт ITU-T X.800) определяет построение защищённых систем путём распределения услуг и способов обеспечения безопасности по уровням модели OSI. Основные компоненты архитектуры:

1) Услуги безопасности: Это дополнительные функции, предоставляемые системой. К ним относятся:

- Аутентификация (взаимодействующего субъекта и источника данных)
- Управление доступом
- Конфиденциальность данных (соединения, без установления соединения, полей, трафика)
- Целостность данных (с восстановлением и без, для полей и потоков)
- Неотказуемость (защита от отказа отправителя или получателя)

2) Способы обеспечения безопасности (механизмы): Это инструменты для реализации услуг. Основные из них:

- Шифрование
- Электронная цифровая подпись (ЭЦП)
- Управление доступом
- Обмен аутентификационной информацией
- Заполнение трафика и др.

Принципы архитектуры: Услуги и механизмы встраиваются на разные уровни OSI с целью минимизации дублирования, сохранения независимости уровней и обеспечения функциональной надёжности.

5. Принципы архитектуры безопасности сети Интернет

— Архитектура безопасности сети Интернет не имеет единого международного стандарта (в отличие от ЭМВОС) и является комбинацией подходов из различных моделей, включая ЭМВОС, модель МО США и разработки рабочей группы IETF/IETF.

Несмотря на разное количество уровней (5 в Интернете против 7 в ЭМВОС), базовые услуги и способы обеспечения безопасности остаются аналогичными. Безопасность в Интернете обеспечивается путём распределения этих услуг (аутентификация, управление доступом, конфиденциальность, целостность и т.д.) по уровням его архитектуры.

Основная практическая разработка и стандартизация протоколов безопасности для Интернета осуществляется рабочей группой IETF.

6. Общие концепции обеспечения ИБ

— Общие концепции обеспечения информационной безопасности (ИБ) определяют фундаментальные принципы и компоненты для построения систем защиты. К ним относятся:

1) Вспомогательная информация (ВИ): Данные, необходимые для работы служб безопасности (политики безопасности, аутентификационная информация, метки безопасности, сертификаты).

2) Сетевой сегмент безопасности (ССБ): Логическая зона, объединяющая элементы (системы, пользователей, данные) под управлением единого центра безопасности, который реализует политику безопасности (ПЛБ) — набор правил и требований к защите.

3) Правила безопасного взаимодействия (ПБВ): Специальные правила, регулирующие обмен данными и совместную деятельность между разными ССБ.

4) Надёжные (доверенные) объекты/субъекты: Компоненты системы, которые могут нарушить политику безопасности, но считаются надёжными в рамках определенных видов деятельности. Бывают условно и безусловно надёжными.

5) Доверие: Уверенность одного субъекта в том, что другой субъект функционирует корректно. Доверие не всегда является взаимным или транзитивным.

6) Третья доверенная сторона (ДТС): Надёжный независимый объект (например, удостоверяющий центр или нотариус), предоставляющий услуги безопасности другим субъектам.

7. Общая информация для обеспечения безопасности

— Общая информация для обеспечения безопасности (ВИ) — это вспомогательные данные, необходимые для функционирования служб безопасности. Она существует в четырёх основных формах:

1) Метки безопасности: Набор атрибутов, который "привязывается" к данным, субъекту или каналу связи и определяет, как с ними следует обращаться в соответствии с Политикой безопасности (ПЛБ). Например, уровень конфиденциальности или требования к шифрованию.

2) Криптографические проверочные суммы (КПС): Данные, полученные в результате криптографического преобразования, которые используются для проверки целостности информации. Основные виды:

- Криптоконверт (Seal): Формируется с помощью симметричного шифрования.
- Электронная цифровая подпись (ЭЦП): Формируется с помощью закрытого ключа.
- Цифровой отпечаток (Digital Fingerprint): Уникальная характеристика данных.

3) Сертификаты безопасности (СЕРТ|ИБ): Цифровой документ, выпущенный Центром безопасности или Удостоверяющим центром, который удостоверяет подлинность и принадлежность какой-либо информации (например, открытого ключа). Сертификаты имеют срок действия, могут быть отозваны и объединяться в цепочки доверия.

4) Маркеры безопасности: Защищённые блоки данных, которые передаются между взаимодействующими сторонами (но не центром безопасности) для обмена вспомогательной информацией в течение сеанса связи.

8. Общие средства обеспечения безопасности

— Общие средства обеспечения безопасности (СРБ) делятся на два основных класса:

1) Вспомогательные (обеспечивающие) средства:

- Это инструменты для управления и поддержки жизненного цикла вспомогательной информации (ВИ).
- Примеры: Средства для установки, изменения, привязки, распределения, регистрации и удаления ВИ, а также для блокировки служб безопасности.

2) Функциональные средства:

- Это инструменты, которые непосредственно участвуют в процедурах обеспечения безопасности (ПРБ).
- Примеры: Средства для идентификации доверенных центров безопасности и правил взаимодействия, а также средства для запроса, формирования и проверки ВИ, необходимой для конкретных служб (например, для управления доступом или аутентификации).

9. Взаимосвязи между СПБ

— Взаимосвязи между способами обеспечения безопасности (СПБ) возникают, когда для защиты требуется одновременное использование нескольких служб безопасности (СЛБ). Ключевой момент — порядок их применения, особенно для криптографических методов.

- Основное правило: Целесообразно сначала применять средства целостности (ЭЦП) или неотказуемости, а затем — конфиденциальности (шифрование). Это обеспечивает корректную проверку подписи получателем.
- Обратный порядок (сначала шифрование): Иногда необходим, когда промежуточному узлу (например, ретранслятору) нужно проверить целостность сообщения, но запрещено знать его содержание. Однако это лишает получателя доказательств неотказуемости отправителя.
- Решение для трёх служб: Если нужны конфиденциальность, целостность и неотказуемость, но порядок обратный, можно использовать две отдельные подписи — одну по открытому тексту (для неотказуемости), а другую по шифртексту (для проверки целостности промежуточными узлами).

10. Отказ в обслуживании и доступность

— Отказ в обслуживании (DoS-атака) — это событие, при котором качество обслуживания падает ниже требуемого уровня или услуга становится полностью недоступной. Это может быть вызвано как злонамеренной атакой, так и нештатными событиями (катастрофами).

Доступность — это условие, при котором отказ в обслуживании невозможен.

Для противодействия отказам используются службы безопасности (СЛБ), которые:

- Выявляют условия отказа.
- Регистрируют события для аудита и подают сигнал тревоги.
- Проводят корректирующие процедуры для восстановления приемлемого уровня обслуживания.

Способы защиты от DoS-атак варьируются в зависимости от защищаемой системы, и не существует единого стандартного метода для их классификации.

11. Вспомогательная информация и средства аутентификации

— Для проведения аутентификации используются три типа вспомогательной информации (ВИАУ):

1) Предъявляемая ВИАУ: Это секретные данные, которые предъявляет субъект для подтверждения своей подлинности.

Примеры: Пароль, секретный ключ, закрытый ключ.

2) Проверочная ВИАУ: Это эталонная информация, которая хранится у проверяющей стороны для сверки с предъявленными данными.

Примеры: Эталонный пароль, секретный ключ, открытый ключ. Может храниться в защищённой таблице аутентификации или в сертификате.

3) ВИАУ для обмена: Это данные, которые непосредственно передаются между сторонами (претендентом и проверяющим) в процессе аутентификации.

Примеры: Запрос, ответ на запрос, случайное число, результат криптографического преобразования, сертификат. Часто передаются в виде маркера безопасности.

Сертификаты (СЕРТ|АУ) — это основной способ представления ВИАУ, выпускаемый Удостоверяющим Центром (УЦ). Бывают:

- Интерактивные: Создаются по запросу.
- Независимые: Связывают владельца с ключом (например, в PKI).
- Сертификаты отзыва (СЕРТ|ОТ/СОС): Для аннулирования compromised-сертификатов.

Средства аутентификации делятся на:

- Вспомогательные: Управляют жизненным циклом ВИАУ (регистрация, изменение, блокировка, удаление).
- Функциональные: Непосредственно выполняют аутентификацию:
 - Запрос: Получение данных для начала аутентификации.
 - Формирование: Создание ВИАУ для обмена (на стороне претендента).
 - Проверка: Верификация ВИАУ (на стороне проверяющего).

12. Свойства способов аутентификации

— Свойства способов аутентификации определяются по нескольким ключевым признакам:

По типу используемой информации:

- Симметричные: Обе стороны используют общий секрет (пароль, общий ключ).
- Асимметричные: Стороны используют разные, но математически связанные данные (например, пару из открытого и закрытого ключей).

По применению криптографии:

- Криптографические: Используют шифрование для защиты данных аутентификации (например, защищённый обмен паролем).
- Некриптографические: Используют открытые данные (например, простые пароли, запросно-ответные таблицы).

По количеству проверяемых сторон:

- Односторонняя: Подлинность проверяется только у одной стороны.
- Обоюдная (взаимная): Подлинность проверяется у обеих сторон одновременно, часто без удвоения количества передаваемых сообщений.

По подтверждению результата:

- Квитирование: Может использоваться отправка подтверждения (квитанции) о результате аутентификации (положительном или отрицательном).

13. Способы аутентификации

— Способы аутентификации классифицируются по их устойчивости к угрозам на следующие классы:

- Класс 0 (Незащищённый): Простая передача пароля. Уязвим к раскрытию и повторной передаче.
- Класс 1 (Защита от раскрытия): Передается преобразованное значение (например, хэш пароля). Защищает от раскрытия секрета, но уязвим к повторной передаче.
- Класс 2 (Защита от раскрытия и повтора разными проверяющими): Использует уникальный параметр проверяющей стороны. Защищает от атак с разных систем.
- Класс 3 (Защита от раскрытия и повтора одной проверяющей стороной): Использует уникальные числа (случайные числа, метки времени). Защищает от повторного использования данных одной и той же системой.
- Класс 4 (Максимальная защита): Включает несколько подвидов (4a-4d), наиболее распространенным из которых является "запрос-ответ" (challenge-response). Проверяющая сторона отправляет случайный запрос, а претендент возвращает ответ, вычисленный с использованием своего секрета. Это защищает и от раскрытия, и от любой повторной передачи.

Для повышения безопасности широко используются криптографические методы (шифрование, электронная подпись), а также доверенные третьи стороны (Удостоверяющие Центры) для выдачи сертификатов.

14. Взаимодействие с другими СЛБ и СПБ

— Служба аутентификации тесно взаимодействует с другими службами безопасности, выполняя для них базовую функцию:

- Управление доступом: Результаты аутентификации (идентификация субъекта) передаются службе управления доступом для принятия решений о разрешении или запрете доступа к ресурсам.
- Целостность и Конфиденциальность данных: В процессе аутентификации часто происходит распределение ключевой информации (явно или неявно), которая затем используется этими службами для шифрования и обеспечения целостности данных.
- Неотказуемость: Аутентификация может предоставить ключевую информацию или доказательства, необходимые для подтверждения авторства действий или данных.
- Аудит: Служба аутентификации поставляет данные для аудита: результаты проверок подлинности, информацию об аннулировании учетных данных и другие события, связанные с процессом аутентификации.

15. Персонализация (аутентификация пользователей)

— Персонализация (аутентификация пользователей) — это проверка подлинности физических лиц. Она основана на одном или нескольких принципах:

- 1) Знание чего-либо: Самый распространенный метод — использование пароля.
- 2) Обладание чем-либо: Использование физического носителя, например:
 - Карты с магнитной полосой (ненадежны, так как легко копируются).
 - Смарт-карты (более надежны, могут требовать двухфакторной аутентификации).
 - Нестационарного генератора паролей (устройство, генерирующее одноразовые коды на основе времени и PIN-кода).
- 3) Индивидуальные характеристики (Биометрия): Использование уникальных физиологических или поведенческих черт:
 - Отпечатки пальцев, рисунок сетчатки, тембр голоса.
 - Собственноручная подпись (статическая или динамическая).
 - Динамика печати на клавиатуре (обеспечивает непрерывную аутентификацию).
- 4) Подтверждение доверенной третьей стороной (ДТС).
- 5) Контекст (например, IP-адрес).

Отдельно рассматриваются виртуальные представительства пользователя, которые могут действовать в системе от его имени без его постоянного присутствия.

16. Аутентификация в ЭМВОС и Интернет-архитектуре

— В архитектурах ЭМВОС и Интернет аутентификация реализуется на трёх верхних уровнях и делится на два типа:

- 1) Аутентификация взаимодействующего объекта (субъекта): Подтверждает подлинность одной или обеих сторон соединения (устройства, процесса, пользователя).
- 2) Аутентификация источника данных: Подтверждает, от кого именно поступили данные, но не защищает от их повторной передачи.

Распределение по уровням:

- Сетевой уровень (3): Аутентифицирует сетевые узлы (маршрутизаторы, шлюзы) и источник сетевых пакетов.
- Транспортный уровень (4): Аутентифицирует оконечные системы (хосты) и источник сегментов данных.
- Прикладной уровень (5 в Интернет / 7 в ЭМВОС): Аутентифицирует конкретные приложения, службы или пользователей и источник прикладных данных.

17. Практические аспекты парирования атак

— Для практической защиты от атак типа «повторная передача» используются два основных метода:

- 1) Уникальные числа (генерируются претендентом)
 - Запись всех использованных чисел непрактична из-за большого объема памяти.
 - Практичное решение: Использование меток времени в составе числа. Это позволяет проверяющей стороне хранить только числа за последний короткий промежуток (несколько минут), экономя память.
 - Для защиты от коллизий и DoS-атак уникальное число должно выбираться из достаточно большого диапазона (например, комбинация метки времени и случайного числа).

2) Встречные запросы (генерируются проверяющей стороной):

- Запись всех отправленных запросов также ведет к проблемам с памятью.
- Практичные решения:
 - Использование последовательных номеров и хранение только последнего номера.
 - Использование случайных чисел из очень большого диапазона, что сводит вероятность повтора к минимуму.
 - Использование меток времени или их комбинации со случайными числами в запросе.

18. Защита процедуры аутентификации

— Для защиты процедуры аутентификации от атак типа «повторная передача» и «перехват» применяются следующие основные методы:

1) Против повторной передачи одной и той же проверяющей стороне:

- Уникальные числа: Претендент генерирует уникальное число (например, на основе метки времени или случайного значения), которое проверяющая сторона принимает только один раз.

2) Против повторной передачи разным проверяющим сторонам:

- Встречные запросы (Challenge-Response): Проверяющая сторона генерирует уникальный запрос (челлендж), на который претендент должен дать правильный ответ, используя свой секрет.
- Использование уникального параметра проверяющей стороны: Ответ претендента дополнительно зависит от уникального атрибута проверяющей стороны (например, её сетевого адреса или имени).

3) Против перехвата и адаптивных атак («человек посередине»):

- Индикатор «приглашение/запрос»: Ответ претендента формируется по-разному в зависимости от того, сам ли он инициировал аутентификацию («запрос») или откликнулся на приглашение проверяющей стороны («приглашение»). Это не позволяет атакующему подменить контекст.
- Криптографическая привязка: В процессе аутентификации стороны вырабатывают общий сеансовый ключ, который затем используется для обеспечения целостности или конфиденциальности последующего обмена, подтверждая легитимность участников.

19. Примеры способов аутентификации

— В разделе приведены два примера защищённых способов аутентификации, использующих интерактивный сертификат (CERT|AU), выданный Доверенной Третьей Стороной (ДТС).

1) Способ на основе уникального числа (nonce):

- Суть: Претендент генерирует уникальное число (nonce) и преобразует его с помощью функции F, используя свой секрет (Внешний Контрольный Параметр, ВКП). Результат и сертификат отправляются проверяющей стороне.
- Защита: Гарантирует свежесть обмена и защищает от повторной передачи. Проверяющая сторона проверяет подлинность, используя открытую часть ключа из сертификата, и убеждается, что данное уникальное число не использовалось ранее.

2) Способ на основе встречного запроса (challenge-response):

- Суть: Проверяющая сторона отправляет случайный запрос (challenge). Претендент преобразует этот запрос с помощью функции F и своего секрета (ВКП). Полученный ответ и сертификат отправляются обратно.
- Защита: Доказывает, что претендент владеет секретом, не раскрывая его. Проверяющая сторона, зная открытую часть ключа из сертификата, может верифицировать ответ.

Общие элементы для обоих способов:

- Функция преобразования (F): Может быть однонаправленной функцией (хеш), алгоритмом асимметричного (ЭЦП) или симметричного шифрования (шифрование/проверочная сумма).
- Роль сертификата: Связывает идентификатор пользователя с его открытым ключом или другим проверочным параметром, удостоверяя эту связь подписью ДТС.
- Применимость: Оба способа подходят для аутентификации как взаимодействующей стороны (объекта), так и источника данных.

20. Политики УД

— Политики управления доступом (ПЛУД) — это набор правил, определяющих, кто, к каким ресурсам и при каких условиях имеет доступ. Они являются частью общей политики безопасности (ПЛБ) в сетевом сегменте безопасности (ССБ).

Ключевые аспекты политик УД:

1) Типы политик:

- На основе правил (УДПР): Единые для всех правила (например, "запрещён доступ с внешних IP-адресов").
- На основе аутентификации (УДПП): Правила, привязанные к конкретному пользователю, группе или роли (например, "только бухгалтерам разрешён доступ к финансовой системе").

2) Способы определения доступа:

- Группы и роли: Объединение пользователей для упрощения назначения прав (например, группа "Бухгалтерия", роль "Директор").
- Метки безопасности: Использование меток (грифов) для принятия решений на основе уровня конфиденциальности (например, "Секретно", "Для служебного пользования").
- Политики для нескольких инициаторов: Требование согласия нескольких пользователей для критичных операций (принцип "двух пар глаз").

3) Аспекты обеспечения (enforcement):

- Фиксированные: Встроены в систему и не могут быть изменены.
- Административные: Устанавливаются и изменяются только администраторами.
- Выбираемые пользователем: Пользователь может сам определять политики доступа к своим ресурсам.

Другие важные концепции:

- Детализация и локализация: Политики могут применяться на разных уровнях (например, ко всему серверу, к конкретной папке или к отдельному полю в базе данных).
- Унаследованные правила: Автоматическое присвоение прав доступа новому объекту на основе прав родительского объекта или его создателя.
- Приоритет правил: Механизм разрешения конфликтов, когда несколько правил применяются к одному запросу доступа.
- Правила по умолчанию: Действуют, если для запроса нет явно заданного правила (например, "запрещать всё, что не разрешено явно").
- Согласование политик между ССБ: Необходимость преобразования атрибутов доступа (например, идентификаторов пользователей) при взаимодействии разных security-доменов с различными политиками.

21. Вспомогательная информация и средства УД

— Вспомогательная информация для управления доступом (ВИУД) — это данные, на основе которых принимается решение о предоставлении или запрете доступа. Она делится на несколько типов:

1) Типы ВИУД:

- Об инициаторе: Идентификаторы пользователя, группы, роли, метки безопасности.
- О целевом объекте: Идентификаторы ресурса, метки конфиденциальности или целостности.
- О запросе доступа: Тип операции (чтение, запись), требуемый уровень целостности.
- Об объекте обработки: Метки данных, с которыми производится операция.
- Контекстно-зависимая информация: Время, местонахождение, маршрут доступа, состояние системы.

2) Защита ВИУД:

- Сертификаты УД (СЕРТ|УД): Цифровые документы, выданные удостоверяющим центром, которые защищают целостность ВИУД и удостоверяют её подлинность.
- Маркеры УД: Формируются инициатором для привязки ВИУД к конкретному запросу доступа.

3) Средства УД: Инструменты для работы с ВИУД и принятия решений.

- Вспомогательные средства: Управляют жизненным циклом ВИУД (установка, изменение, удаление, блокировка).
- Функциональные средства: Непосредственно участвуют в процессе контроля доступа:
 - Запрос ВИУД: Получение необходимой информации об инициаторе или целевом объекте.
 - Формирование ВИУД: Создание защищённого пакета данных (маркера или сертификата) для запроса доступа.
 - Проверка ВИУД и извлечение ВИПР: Верификация подлинности ВИУД и извлечение из неё правил для принятия решения.
 - Получение контекстной информации: Сбор дополнительных контекстных данных (время, местоположение).
 - Принятие решения о доступе: Функция принятия решения (ФПРР-модуль) на основе всей собранной информации (ВИПР и контекста) разрешает или запрещает доступ.

22. Классификация способов УД

— Способы управления доступом (УД) классифицируются на основе схемы хранения и использования вспомогательной информации (ВИУД). Выделяют четыре основные схемы:

1) На основе списков доступа (УДСД):

- Суть: Права доступа хранятся у целевого объекта (ресурса) в виде списка, где для каждого инициатора (пользователя, группы, роли) указаны разрешённые операции.
- Плюсы: Высокая детализация, удобно для управления доступом к конкретному ресурсу.
- Минусы: Неудобно при частом изменении состава пользователей.

2) Мандатная схема:

- Суть: Права доступа хранятся у инициатора в виде "мандата" – токена, который определяет, к каким ресурсам и какие операции разрешены.
- Плюсы: Удобно для управления правами пользователя, легко делегировать права.
- Минусы: Сложно оперативно отозвать доступ к ресурсу для всех пользователей.

3) На основе меток безопасности (УДМБ):

- Суть: И инициаторам, и целевым объектам присваиваются метки (например, грифы секретности). Решение о доступе принимается путем сравнения этих меток согласно политике безопасности.
- Плюсы: Эффективна для крупных систем с большим количеством пользователей и ресурсов, позволяет управлять потоками данных.
- Минусы: Требуется строгая централизованная политика.

4) Контекстная схема:

- Суть: Доступ предоставляется или запрещается на основе контекстной информации: времени, местоположения пользователя, сетевого адреса, состояния системы и т.д.
- Плюсы: Позволяет реализовать гибкие политики, зависящие от обстоятельств.
- Минусы: Часто используется не самостоятельно, а в комбинации с другими схемами.

На практике системы часто используют комбинацию этих схем для достижения максимальной гибкости и безопасности.